Relatório de segunda validação

Frontend e backend | Projeto Gestão Financeira | 17 de outubro de 2026

Objetivo Conferir no código atual os achados dos agentes e separar confirmações, falsos positivos e riscos condicionais.	**Escopo** Inspeção estática dos arquivos indicados. Nenhum arquivo-fonte foi alterado e nenhum teste foi executado.

Resumo executivo

Status	Conclusão da segunda revisão
Confirmado	XSS por dados interpolados em HTML; falha de redirecionamento após 401 em páginas MPA; avatar do chat com token em query não aceito pelo middleware; ausência de rowCount em duas atualizações backend; template de contato público sem escape.
Falso positivo	Token novo da troca de senha é persistido; IDs dos modais citados correspondem aos scripts; fluxo atual de recuperação usa endpoint ativo; não existe exclusão de planejamento pai; botão de relatórios aparece ao selecionar o tipo.
Condicional	XSS no reset-password depende da mensagem retornada; atualização de pagamento via notificação pode usar person_id ausente/incorreto; FK impede exclusões associadas e NOT VALID não confere registros antigos.

Achados confirmados

1. XSS nas telas de eventos e uniformes [ALTO]

Referência: public/js/events.js:275-312; public/js/uniformes.js:46-56, 358-414

Nomes, unidades e dados de pedidos entram em innerHTML sem escape. Se esses valores vierem de registros manipuláveis, conteúdo HTML/JavaScript pode ser renderizado ao abrir as telas ou a impressão. Recomenda-se escapar todo dado dinâmico ou construir nós com textContent.

2. Sessão expirada sem redirecionamento nas páginas MPA [ALTO]

Referência: public/js/core.js:774-799

O tratamento de 401 limpa o token, mas só alterna a interface se #login-section e #main-section existirem. Nas páginas MPA, o usuário pode permanecer na tela atual sem ser levado ao login. Recomenda-se redirecionar explicitamente para a página de login.

3. Avatar do chat usa token em query string não autorizada [MÉDIO]

Referência: public/js/chat.js:76, 157; lib/security.js:14

O frontend solicita o avatar com ?token=, enquanto a lista de exceções do middleware não inclui essa rota. A chamada tende a retornar 401. Ajustar o mecanismo de autenticação da mídia ou a regra específica de autorização.

4. Pagamento aberto pela notificação pode enviar person_id errado [MÉDIO]

Referência: public/js/core.js:1106-1110; public/js/events.js:500-503; public/js/ui.js:335-337

O fluxo pela grade grava tempPaymentPersonId. O fluxo administrativo por notificação pode não atualizar esse estado antes de permitir “Atualizar Valor”; a API então pode receber ID ausente ou antigo. Definir o ID ao abrir o modal e validar o payload.

5. Atualizações de atividade/cardápio não verificam registro afetado [BAIXO]

Referência: routes/plannings.js:153, 168

As duas rotas podem responder sucesso mesmo quando nenhum registro corresponde ao ID. Verificar rowCount e responder 404 se nada foi atualizado.

6. Formulário público interpola dados em template de e-mail sem escape [MÉDIO / CONDICIONAL]

Referência: server.js:151-262

O endpoint de contato público interpola campos enviados pelo visitante diretamente no HTML, inclusive mensagem e dados de contato. O helper de escape em utils/emailTemplates.js não cobre esse template inline. Escapar conteúdo HTML e validar tamanho/formato; o impacto depende do cliente de e-mail que renderiza.

Falsos positivos descartados

Troca obrigatória de senha revoga a sessão [FALSO POSITIVO]

Referência: public/js/ui.js:104-114; routes/secureAuth.js:58-59

O frontend lê changed.token, atualiza state.token e persiste o token novo antes de continuar.

Perfil permite troca de senha mas falha por falta de currentPassword [FALSO POSITIVO]

Referência: public/js/profile.js:1-103; public/profile.html:262-309

Não há formulário nem chamada de troca de senha no perfil atual. A funcionalidade descrita no achado original não existe nesses arquivos.

Recuperação de senha aponta para endpoint 410 [FALSO POSITIVO]

Referência: public/js/ui.js:35-82

O fluxo ativo envia para /api/auth/forgot-password-email. O endpoint reset-lost-password não é chamado pelo JavaScript atual.

IDs dos modais de membros/eventos/planejamentos/especialidades estão divergentes [FALSO POSITIVO]

Referência: public/people.html:734-833; public/events.html:460-463; public/planejamentos.html:1130-1197; public/especialidades.html:301-373

Os IDs verificados correspondem aos seletores usados pelos scripts nas páginas próprias. Há cópias órfãs de alguns modais em outras páginas, mas não sustentam a alegação geral de quebra nas páginas citadas.

Exclusão de planejamento pai retorna 404 [FALSO POSITIVO]

Referência: public/js/planejamentos.js:382-400; routes/plannings.js:110-131

O frontend só exclui atividades e cardápios, e ambas as rotas existem. Não foi encontrada chamada de exclusão do planejamento pai.

Botão de gerar relatório fica sempre oculto [FALSO POSITIVO]

Referência: public/js/reports.js:454-478, 514; public/reports.html:272-315, 892

toggleReportFields controla display conforme o tipo selecionado. O modal citado como duplicado não foi encontrado com esse ID.

Achados condicionais e observações

reset-password.html:91-95 - A interpolação de data.message é real, mas a resposta atual do backend não parece fornecer mensagem controlada pelo usuário; o risco de XSS por esse caminho não foi confirmado.

migrations/004_event_payment_participant.sql:4-8 - A FK pode impedir excluir inscrição com pagamento vinculado. Como foi criada NOT VALID, novas gravações respeitam a regra, mas registros antigos permanecem sem validação até auditoria e eventual VALIDATE CONSTRAINT.

public/login.html:328-331; lib/validation.js:51 - Texto da interface informa requisito de senha menor do que a validação real (mínimo de 10 caracteres com letras e números). Atualizar o texto para reduzir tentativas rejeitadas.

public/js/ui.js:152-154; routes/securePeople.js:92 - O relatório anterior alegou 400 por responsiblePassword, mas o valor enviado nessa edição é constante vazio. A alegação de erro nessa rota é falso positivo.

public/js/financial.js:92, 398; public/js/chat.js:76, 157 - Há JWT em query strings para alguns recursos. Além do problema confirmado no avatar, tokens em URL podem aparecer em histórico/logs; avaliar alternativas por cabeçalho ou cookie onde aplicável.

Limitações

Esta validação foi estática e somente leitura. Não foram executados testes automatizados, fluxos em navegador, uploads, envio real de e-mails ou integrações externas. Os arquivos locais já tinham alterações pendentes antes desta tarefa; este relatório não altera nem substitui essas mudanças. Prioridade sugerida: XSS e 401; depois avatar, pagamento e rowCount.